TITLE OF THE PROJECT

Enforce least-privilege access through identity-aware, application specific access policies using Zscaler Private Access (ZPA).

OVERVIEW:

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify." By moving beyond location-based access, we aim to establish a security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity.

.

The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, rendering the applications invisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks.

Ultimately, this project will enforce a least-privilege access model, ensuring users and devices are granted the minimum required access necessary to perform their functions. By decoupling application access from network access, we will eliminate the risk of lateral movement across the network, as users have no visibility or connectivity to other hosts. This strategic move not only significantly enhances security by reducing the attack surface but also simplifies the user experience and reduces operational overhead associated with legacy remote access infrastructure, positioning the organization at the forefront of secure and efficient access management.

TEAM ID: SWTID-2026-4963
TEAM SIZE:4

LIST OF TEAM MEMBERS:

S.NO	NAME	COLLEGE	CONTACT
1	MANIMEKALAI.A	PPG COLLEGE OF ARTS AND SCIENCE	2328b0004.cas@ppg.edu.in
2	MANASA.M	PPG COLLEGE OF ARTS AND SCIENCE	2328b0003.cas@ppg.edu.in
3	KARTHIKA.K	PPG COLLEGE OF ARTS AND SCIENCE	2328b0002.cas@ppg.edu.in
4	BALAJI.M	PPG COLLEGE OF ARTS AND SCIENCE	2328b0001.cas@ppg.edu.in

STAGE 1

LIST OF VULNERABILITY TABLE :

S.NO	CATEGORY NAME	VULNERABILITY NAME	CWE/CVE - NO
1	Broken access control	Incorrect default permissions	CWE-276

REPORT

Vulnerability Name:Incorrect Default permissions

CWE/CVE : 276

OWASP/SANS Category: A01:2025 Broken Access Control

Description: Incorrect default permissions occur when a system, application, or resource is deployed with overly permissive access settings. This can allow unauthorized users to read, modify, or execute files, settings, or functionalities that should be restricted. Attackers can exploit these misconfigurations to gain elevated privileges, access sensitive data, or compromise system integrity.

Business Impact: Exploitation of incorrect default permissions can lead to unauthorized data exposure, privilege escalation, system compromise, and potential regulatory violations. This can cause financial loss, reputational damage, and legal liabilities for the organization.

STAGE 2

OVERVIEW :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests. Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability. Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

TARGET WEBSITE : https://public-firing-range.appspot.com/

TARGET IP ADDRESS: 142.250.190.244

LIST OF VULNERABILITY:

S.NO	VULNERABILITY NAME	SEVERITY	PLUGINS
1	HTTP (Multiple Issues)	mixed	-
2	SSL (Multiple Issues)	Info	-
3	TLS (Multiple Issues)	Info	-

4	TLS (Multiple Issues) (another plugin entry)	Info	-
5	Web Server (Multiple Issues)	Info	-
6	Service Detection	Info	22964
7	Nessus SYN Scanner	Info	11219
8	Additional DNS Hostnames	Info	46180
9	Host Fully Qualified Domain Name (FQDN) Resolution	Info	12053
10	Nessus Scan Information	Info	19506
11	OS Fingerprints Detected	Info	209654
12	Remote Services Not Using Post-Quantum Ciphers	Info	277650
13	Shor's Harvest Now Decrypt Later	Info	298387
14	SSL Root Certification Authority Certificate Information	Info	94761
15	TLS Version 1.2 Protocol Detection	Info	136318
16	Traceroute information	Info	10287

REPORT 1

- Vulnerability Name: HTTP (Multiple Issues)
- Severity: Mixed
- Plugin: —
- Description: Multiple HTTP-related informational and possibly misconfiguration issues (e.g., server version banner disclosure, missing security headers, etc.) typically detected during a web service scan.
- Solution: Review specific HTTP plugin outputs in the full scan report; remediate misconfigurations such as disabling unnecessary modules, enforcing secure headers, and updating the web server to the latest patched version.
- Business Impact: Information leakage can help attackers fingerprint servers and plan targeted attacks; mixed severity means some findings may enable future exploitation.

REPORT 2

- Vulnerability Name: SSL (Multiple Issues)
- Severity: Info
- Plugin: —
- Description: SSL/TLS configuration may have non-optimal settings or weak cryptographic parameters (informational).
- Solution: Configure SSL protocols and ciphers securely (disable deprecated protocols such as SSLv3; enable secure cipher suites).
- Business Impact: Weak SSL configurations can reduce trust and potentially allow downgrade attacks or weak encryption; impacts confidentiality.

REPORT 3

- Vulnerability Name: TLS (Multiple Issues)
- Severity: Info
- Plugin: —
- Description: TLS configuration issues detected, likely informational only, such as supported versions or ciphers.
- Solution: Harden TLS settings according to industry best practices (disable TLS 1.0/1.1; enable TLS 1.3 where possible).
- Business Impact: Suboptimal TLS configuration can expose systems to protocol-based weaknesses and may lower compliance posture.

REPORT 4

- Vulnerability Name: TLS (Multiple Issues) (duplicate entry)
- Severity: Info
- Plugin: —
- Description: Same as above; informational TLS settings.

- Solution: See Report 3.
- Business Impact: Same as Report 3.

REPORT 5

- Vulnerability Name: Web Server (Multiple Issues)
- Severity: Info
- Plugin: —
- Description: Multiple informational web server related issues (often version disclosures, default pages, server type info exposed).
- Solution: Update web server, hide version banners, and fix weak configurations.
- Business Impact: Attackers can leverage web server information for targeted exploits; informational issues can aid reconnaissance.

REPORT 6

- Vulnerability Name: Service Detection
- Severity: Info
- Plugin: 22964 — Service Detection
- Description: Nessus successfully identified the remote service(s) running on the detected ports. This is informational only and indicates what services are exposed.
- Solution: None required; this is informational only. If unnecessary services are detected, consider disabling them.
- Business Impact: Knowledge of exposed services assists in risk assessment and prioritization of hardening, but this plugin does not indicate a vulnerability itself.

REPORT 7

- Vulnerability Name: Nessus SYN Scanner
- Severity: Info
- Plugin: 11219 — Nessus SYN Scanner
- Description: Nessus performed a SYN "half-open" scan to discover open ports on the target.
- Solution: No direct fix — this is part of the scanning process. Ensure proper firewall/IP filtering to control unauthorized scanning.
- Business Impact: Informational; identifies reachable services. Helps build an inventory of exposed ports for security planning.

REPORT 8

- Vulnerability Name: Additional DNS Hostnames
- Severity: Info
- Plugin: 46180 — Additional DNS Hostnames

- Description: Nessus detected alternate DNS names pointing to the same host, indicating multiple virtual hosts.
- Solution: Review and map out all DNS names. Re-scan using vhost syntax to ensure coverage.
- Business Impact: Extra hostnames can expand the attack surface; attackers might target unmonitored or less secured vhosts

REPORT 9

- Vulnerability Name: Host Fully Qualified Domain Name (FQDN) Resolution
- Severity: Info
- Plugin: 12053
- Description: Nessus resolved the FQDN for the host. Typically informational about how the host resolves in DNS.
- Solution: N/A — informational DNS mapping.
- Business Impact: Useful for asset inventory; no direct exploit.

REPORT 10

- Vulnerability Name: Nessus Scan Information
- Severity: Info
- Plugin: 19506 — Nessus Scan Information
- Description: Provides details about the scan itself (policy, settings, elapsed time, etc.).
- Solution: None — informational.
- Business Impact: Helps in scan analysis and validation.

REPORT 11

- Vulnerability Name: OS Fingerprints Detected
- Severity: Info
- Plugin: 209654 — OS Fingerprints Detected
- Description: Nessus identified the remote system's operating system based on network responses.
- Solution: None — informational.
- Business Impact: Useful for asset inventory and vulnerability prioritization.

REPORT 12

- Vulnerability Name: Remote Services Not Using Post-Quantum Ciphers
- Severity: Info
- Plugin: 277650 — Remote Services Not Using Post-Quantum Ciphers
- Description: Service does not support post-quantum resistant cipher suites (informational).
- Solution: Enable post-quantum cipher support if required by policy.

- Business Impact: Future- proofing; low current impact.

REPORT 13

- Vulnerability Name: Shor's Harvest Now Decrypt Later
- Severity: Info
- Plugin: 298387 — Shor's Harvest Now Decrypt Later
- Description: Indicates that encrypted traffic could be recorded now and decrypted later if quantum computing becomes practical.
- Solution: Use quantum- resistant ciphers if needed by policy.
- Business Impact: Strategic/long-term confidentiality concerns.

REPORT 14

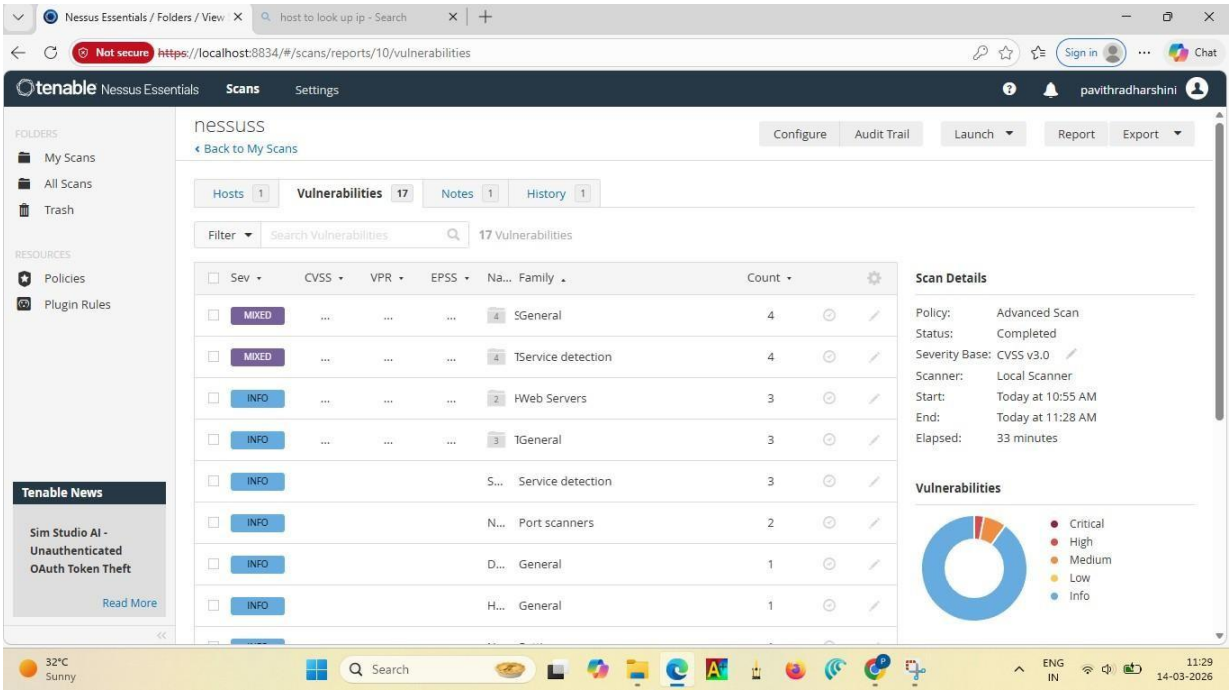
- Vulnerability Name: SSL Root Certification Authority Certificate Information
- Severity: Info
- Plugin: 94761
- Description: Provides information about the SSL root CA certificate used.
- Solution: Ensure trusted CA and valid certificates.
- Business Impact: Helps certificate management; no direct threat.

REPORT 15

- Vulnerability Name: TLS Version 1.2 Protocol Detection
- Severity: Info
- Plugin: 136318
- Description: Detection of TLS 1.2 support on the service.
- Solution: Consider moving to TLS 1.3 where possible.
- Business Impact: Older TLS versions may have weaker security properties.

REPORT 16

- Vulnerability Name: Traceroute Information
- Severity: Info
- Plugin: 10287 — Traceroute Information
- Description: Provides network path information from scanner to host.
- Solution: N/A — informational.
- Business Impact: Helps understand network topology; no direct threat


Nessus Essentials / Folders / View
host to look up ip - Search
Not secure https://localhost:8834/#/scans/reports/10/vulnerabilities
Sign in
Chat
tenable Nessus Essentials
Scans
Settings
pavithradharshini
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
Sim Studio AI - Unauthenticated OAuth Token Theft
Read More
nessuss
Back to My Scans
Configure
Audit Trail
Launch
Report
Export
Hosts 1
Vulnerabilities 17
Notes 1
History 1
Filter
Search Vulnerabilities
17 Vulnerabilities
Sev
CVSS
VPR
EPSS
Na...
Family
Count
MIXED
4 SGeneral 4
MIXED
4 TService detection 4
INFO
2 HWeb Servers 3
INFO
3 TGeneral 3
INFO
S... Service detection 3
INFO
N... Port scanners 2
INFO
D... General 1
INFO
H... General 1
Scan Details
Policy: Advanced Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 10:55 AM
End: Today at 11:28 AM
Elapsed: 33 minutes
Vulnerabilities
Critical
High
Medium
Low
Info
32°C
Sunny
Search
ENG
IN
11:29
14-03-2026

STAGE-3

Title: Enforce least-Privilege access through identity-aware, Application-specific access policies using Zscaler private Access(ZPA).

Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is a modern IT security framework designed to provide secure remote access to internal applications and data based on strict access control policies. Unlike traditional VPNs that grant broad network access, ZTNA operates on a “never trust, always verify” principle. Users are granted access only to the applications they need, after their identity and device posture have been verified.

ZTNA helps organizations move away from the old “castle-and-moat” model, where the internal network was trusted and the outside world was untrusted. By hiding internal resources from the internet and establishing encrypted, one-to-one connections between users and applications, ZTNA drastically reduces the attack surface and prevents lateral movement by attackers.

The ZTNA Access Cycle

The ZTNA access cycle is a continuous process of identity verification, secure connection establishment, and policy enforcement for every access request:

1. **User Request:** The user requests access to an internal application from any location.
2. **Identity and Device Verification:** Multi-factor authentication and device health checks ensure the user and device are authorized.
3. **Policy Enforcement:** The ZTNA solution validates whether the user with a specific device can access the requested application at that time.
4. **Establish Secure Connection:** A secure, encrypted micro-tunnel connects the user to the application, without exposing the network.
5. **Continuous Monitoring:** Connections are monitored in real time for anomalies; suspicious activity triggers automatic termination.
6. **Logging and Analytics:** All activity is logged for auditing, threat hunting, and policy refinement.

This cycle ensures that access is granular, controlled, and continuously validated.

Zscaler (ZIA / ZPA)

Zscaler is a cloud-native security platform that eliminates the need for traditional VPN hardware. For ZTNA, **Zscaler Private Access (ZPA)** enables identity-based access to private applications without exposing users to the network.

Key features:

- **Application-Centric:** Access is granted at the application level, not the network level.
- **Network Hiding:** Internal servers remain invisible to the internet via App Connectors.
- **Cloud-Based:** Scalable and flexible, handling thousands of concurrent users.
- **Enhanced Security:** Integrates with Identity Providers (Azure AD, Okta), device posture tools (CrowdStrike, Tanium), and threat intelligence feeds (MISP).

Zscaler ensures secure, seamless, and scalable access for students, faculty, and staff.

Threat Intelligence

Threat intelligence in a ZTNA environment provides contextual insights to improve security decisions:

- **Zscaler Cloud Logs:** Track user activity across applications.
- **External Threat Feeds (MISP):** Identify malware campaigns and malicious domains.
- **Identity Provider Logs:** Detect anomalies such as impossible travel or suspicious login attempts.

Uses include adaptive access control, hunting compromised accounts, and blocking malicious communication, enabling proactive security measures.

Incident Response (Adapted for ZTNA)

ZTNA improves incident response by isolating threats quickly:

1. **Detection:** SOC monitors anomalies in real time.
2. **Containment:** Access can be instantly revoked at the application level.
3. **Eradication:** Compromised devices are cleaned offline.

4. **Recovery:** Access restored after remediation.
5. **Post-Incident Review:** Policies updated to prevent similar incidents.

Benefits include near-instant containment, elimination of lateral movement, detailed forensics, and compliance support.

Understanding Zscaler ZPA Tool

- Application-centric security, not network-centric.
- Hides internal applications from internet scanning.
- "Dark cloud" approach: apps visible only to authorized users.
- Superior user experience via Client Connector.
- Cloud-scalable solution capable of handling large user bases.

Conclusion

- **Stage 1:** Web application testing emphasized identifying vulnerabilities to ensure secure systems.
- **Stage 2:** Nessus reports highlighted the importance of detailed vulnerability assessments and remediation.
- **Stage 3:** ZTNA with Zscaler demonstrates secure, identity-based access to applications, hiding internal resources, enforcing granular policies, and improving incident response.

Future Scope

- **Web Application Testing:** AI/ML automation, cloud-based testing, advanced UX security assessments.
- **Testing Process:** Continuous testing, automated vulnerability management, predictive security analytics.

- **SOC / SEIM / ZTNA:** AI-driven adaptive access, integration with IoT and edge devices, identity-centric security, SASE convergence, automated threat hunting and response.

Topics Explored

Data Collection & Aggregation, Standardization & Normalization, Enrichment & Analysis, Sharing & Distribution, Integration with Security Tools, Automation & Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, SOC, SIEM

Tools Explored

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite, Zscaler ZPA